CASE STUDY

The Cuckoo's Egg Intrusion: Lawrence Berkeley Laboratory, 1986

A TeamStarWolf case study. Published 3 November 2026; every source checked as of that date.

Executive summary

Many defenders meet this case through a book. *The Cuckoo's Egg* by Clifford Stoll (Doubleday, 1989) tells how a systems manager at Lawrence Berkeley Laboratory (LBL) followed an accounting error to an intruder working from West Germany [4] [7]. It remains a staple of security reading lists, and the library's Cybersecurity Book List carries it [52]. This study goes back to the primary record behind the book: Stoll's own technical paper, "Stalking the Wily Hacker", published in *Communications of the ACM* in May 1988 [1] [2], and the contemporaneous reporting of the West German arrests and trial.

The paper's account is precise and sober. From August 1986 a persistent intruder used LBL as a way station into ARPANET and MILNET. LBL chose to let him keep his access while it printed virtually every session and traced him, a decision that took nearly a year and many organizations to see through [1] (**Confirmed**). Over 10 months LBL watched him try about 450 computers and get into more than 30, mostly with default account names, guessed passwords, passwords left in files and password files he cracked offline [1] (**Confirmed**). On LBL's own machines he gained system-manager rights through a flaw in the GNU Emacs `movemail` utility [1] (**Confirmed**). Fictitious Strategic Defense Initiative (SDI) files, alarmed so that LBL would know who read them, held him on the line for more than an hour while telephone technicians finished the trace to West Germany [1] (**Confirmed**).

The espionage story sits on a different footing. The May 1988 paper declines to speculate whether the intrusions were espionage [1] (**Confirmed**). The link to the Soviet KGB comes from West German press reports of the March 1989 arrests, the August 1989 indictment and the February 1990 verdict at the court in Celle, which convicted three men of selling network data to the KGB for about $54,000 [8] [15] [17] [18] (**Reported**). No judgment text, indictment or official German statement was opened for this study, so no claim about the German proceedings is graded higher than Reported.

Evidence grade: the intruder's methods, the scale of the attempts, LBL's monitoring and the trace route are **Confirmed** from Stoll's paper. The book's details and Stoll's later interviews (the 75-cent discrepancy, the name of the McLean contractor, the name "Operation Showerhead") are **Reported**. The KGB sale, the arrests and the sentences are **Reported** from contemporaneous press. The legacy claims (first honeypot, first intrusion detection, a cause of CERT/CC) are graded case by case in Part 6, and most are **Inferred** or hedged.

Key facts at a glance

Field	Value
Victim and first detection	Lawrence Berkeley Laboratory, August 1986, through an accounting program that would not balance [1]
Primary record	Clifford Stoll, "Stalking the Wily Hacker", *Communications of the ACM* 31(5), pp. 484-497, May 1988, DOI 10.1145/42411.42412 [1] [2] [3]
The book	*The Cuckoo's Egg*, Doubleday, New York, 1989, ISBN 0-385-24946-2 [4] [7]; the book text was not opened for this study
Duration of observation	About 10 months; the trace took nearly a year [1]
Scale	About 450 computers attempted, about 220 reachable, more than 30 entered [1]
Entry methods	Default and common account names and passwords, passwords in files, offline dictionary cracking of password files [1]
Privilege escalation at LBL	GNU Emacs `movemail`, running set-user-ID root, used to plant a script as a periodically run utility [1]
Route	West German dial-up and the Bremen and Karlsruhe university X.25 links, Tymnet, a McLean, Virginia, defense contractor's dial-out modems, LBL, then ARPANET and MILNET [1]
What he reached	Little non-public information; unclassified abstracts of US Army nuclear, biological and chemical warfare plans for central Europe [1]
Cost	Civil liability under California law above $100,000 for computing, network and tracing costs [1]
Arrests	2 March 1989, searches in Hannover, West Berlin, Hamburg and Karlsruhe [8] [12] [16] (**Reported**)
Verdict	Court in Celle, 15 February 1990: Peter Carl, Markus Hess and Dirk Brzezinski convicted, suspended terms up to two years [17] [18] (**Reported**)
ATT&CK record	No ATT&CK group, software or campaign object covers this intrusion; this study's 25 technique mappings are retrospective (Part 9) [51]

Key findings

- **The detection was an accounting check, not a security tool.** The paper says LBL's locally written accounting program could not balance because a new account had no billing address [1] (**Confirmed**). The famous 75-cent figure is from the book and later interviews, not the paper [7] [20] (**Reported**).

- **The intruder used ordinary weaknesses at scale.** Of about 220 machines that answered, 2 percent gave him user access and 2 percent gave him system-manager access, and most of his targets were on MILNET [1] (**Confirmed**). Default names such as root, guest, system and field, and passwords that were English words, names or places, were, in the paper's words, primitive but dismayingly successful [1] (**Confirmed**).
- **One privileged program was enough.** A set-user-ID-root helper that could move files into the system area turned a user account into a system manager [1] (**Confirmed**). On another occasion patching did not end his access: he had hidden privilege-granting programs in system libraries and reused them almost a year later [1] (**Confirmed**).
- **Off-host monitoring is what made the case.** Printers and PCs on RS-232 lines recorded his sessions without touching the operating system, so an intruder with system privileges could not see them [1] (**Confirmed**). The same lesson, shipping logs out of an attacker's reach, applies today (**Inferred**).
- **Deception finished the trace.** Alarmed bait files held him for more than an hour [1] (**Confirmed**). The "honeypot" label is retrospective; the definition cited here is RFC 4949's, from 2007 [32] (**Confirmed** for the definition).
- **Almost nobody reported.** Only five of the hundreds of sites he tried, 1 to 2 percent, contacted LBL after seeing a failed login [1] (**Confirmed**). The paper asks for a central clearinghouse for security reports [1] (**Confirmed**). CERT/CC followed in December 1988, but the documented trigger was the November 1988 Internet worm, not LBL [34] [44] (**Confirmed** for the dates; any causal link to LBL is **Inferred**).
- **The espionage frame grew after the paper.** The paper says the targets suggested espionage and treats the SDI letter as attempted espionage, but declines to say whether the intrusions themselves were espionage [1]; the book frames a KGB spy story [7]; a West German prosecutor's spokesman told *taz* it was certainly not a top espionage case [10] (**Reported**). The Celle judge said West Germany suffered no serious damage [18] (**Reported**).
- **The library needs four corrections.** Two concern this case's row in `NOTABLE_INCIDENTS.md`, one the Morris worm row, and one the MITRE Engage ids in `HONEYPOT_DECEPTION_REFERENCE.md` (Part 7.7).

Top recommendations

1. **Remove default credentials everywhere.** Common account names and default passwords let him into about 5 percent of the machines he tried [1]. CISA's Secure by Design Alert of 15 December 2023 asks manufacturers to eliminate default passwords [49]; owners should inventory and change them (D3FEND Change Default Password).
2. **Block guessable passwords.** A dictionary cracker broke 20 percent of LBL user passwords [1]. NIST SP 800-63B requires checking new passwords against a blocklist of common, expected or compromised values [50] (D3FEND Strong Password Policy).
3. **Keep monitoring out of the intruder's reach.** Ship session and audit records off the host, because the intruder disabled accounting and audit trails wherever he could [1].
4. **Audit privileged helpers.** Inventory set-user-ID and similar privileged programs, and compare system utilities against known-good copies, as LBL did after the case [1] (D3FEND File Integrity Monitoring).
5. **Plant alarmed decoys.** Bait files with read alarms detected and held the intruder [1]; D3FEND Decoy File describes the modern form [47].

6. **Report failed logins and know whom to call.** LBL's lesson is that preparation, including knowing which law enforcement contact to ring, made the difference [1]. Decide in advance whether the site will "protect and proceed" or "pursue and prosecute", as RFC 1244 asks [34].

Scope and method

This study covers the LBL intrusion from its first detection in August 1986 through the West German verdict in February 1990, the intrusion-detection and deception work it sits beside (1980 to 2007), and the incident-response institutions that came after it (1988 to 1997). It follows the method in the case studies README: primary sources first, every claim graded, numbers given as the source states them. Every source in the Sources table was opened on 3 November 2026. The book *The Cuckoo's Egg* was not opened, so every detail that only the book supplies is graded Reported and attributed to the book by title and author, with the source that retells it. Direct quotations are kept under 15 words.

The primary record here is unusual. The main primary is the investigator's own account [1], which is first-hand but also one party's view. The German proceedings are known only through press reports and participants' statements; no court document was opened.

Grade	Meaning in this study
Confirmed	Stated in a primary opened for this study: Stoll's 1988 paper, a participant's own published statement, an RFC, a court opinion, an organization's own history, or the MITRE page or library data file itself
Reported	Stated only in journalism, an interview given decades later, an encyclopedia, or the book as retold by a secondary source
Demonstrated	A public reproduction exists that others can check (no claim in this study needed this grade)
Inferred	The study's own reasoning from Confirmed facts, labelled as such

Part 1: the technical record

All of Part 1 comes from Stoll's paper [1] unless another source is named. ATT&CK ids in brackets are this study's retrospective mappings (Part 9); the paper predates ATT&CK by decades.

1.1 The environment

LBL's computers were reachable over dial-up lines, over Tymnet X.25 ports and from the research networks: ARPANET and MILNET, plus the Magnetic Fusion Energy and High Energy Physics networks, which the intruder also used [1] (**Confirmed**). LBL had let its own Tymnet password become public [1] (**Confirmed**).

1.2 Getting in elsewhere: guessed and default accounts

From LBL he tried about 450 computers over MILNET. He used common account names (root, guest, system, field) with default or common passwords, found valid names with the `who` or `finger` commands, and about 5 percent of the machines let him in [1] (**Confirmed**) [`T1110.001`, `T1078.001`, `T1033`; `T1087.001`, Inferred]. Half of the 450 were unreachable. Of the 220 attempted logins, 5 percent refused the connection, 82 percent failed, 8 percent gave status information, 1 percent gave limited access, 2 percent gave user access and 2 percent gave system-manager access; most targets were MILNET addresses (26.i.j.k) [1] (**Confirmed**).

A defense contractor's phone bills, obtained during the trace, showed hundreds of short calls to modems around the United States, mostly at military bases, where he tried the same common names and passwords. These attacks began months before LBL detected him [1] (**Confirmed**) [`T1133`, Inferred].

1.3 Becoming system manager: GNU Emacs movemail

The session printouts showed him use a subtle bug in the GNU Emacs editor to gain system-manager privileges [1] (**Confirmed**). Emacs mail ran a set-user-ID-root section, `movemail`, that could move a file into another user's directory but did not stop moves into the systems area. He wrote a shell script, used `movemail` to rename and place it so that it passed for a utility the system ran periodically, and became system manager when the system ran it [1] (**Confirmed**) [`T1068`, `T1036.005`; `T1548.001` and `T1053`, Inferred]. He also tried a hole in `/usr/spool/at` and one in `vi`, both already patched at LBL [1] (**Confirmed**).

The paper does not name the scheduler that ran the planted file, so this study does not map the At or Cron sub-techniques (`T1053.002`, `T1053.003`) (**Inferred**, a deliberate omission).

1.4 Looking around: keywords, passwords in files and email

Once on a machine he searched files for keywords such as nuclear, sdi, kh-11 and norad, then scanned for plain-text passwords to other systems; this gave him access mechanisms into a Cray supercomputer [1] (**Confirmed**) [`T1083`, `T1552.001`, `T1213`; `T1005`, Inferred]. He read electronic mail, partly to look for signs that he had been found [1] (**Confirmed**) [`T1114.001`].

1.5 Cracking password files offline

He downloaded encrypted UNIX password files and cracked them on his own machine with a dictionary. Within a week he was logging in with correct passwords that were English words, names or place names [1] (**Confirmed**) [`T1003.008`, `T1110.002`, `T1078`]. The paper reports that fully 20 percent of LBL users' passwords fell to a dictionary-based cracker [1] (**Confirmed**).

1.6 Staying in

On one gateway he created a privileged account and left it unused for six months before using it. He hid privilege-granting programs in system software libraries and came back to them almost a year later, after the original hole had been patched. He occasionally created accounts but preferred to steal existing accounts that nobody was using [1] (**Confirmed**) [`T1136.001`, `T1078.003`, `T1036.005`].

1.7 Staying unseen

He disabled accounting and audit trails where he could, including at Bremen University, and planted Trojan horses to capture passwords passively [1] (**Confirmed**) [`T1685`; `T1056`, Inferred]. He checked who was logged in and left if a system manager was on, scanned email for signs of discovery, and rotated his pathways and network user ids [1] (**Confirmed**) [`T1033`, `T1114.001`].

1.8 The path through the networks

He reached LBL through a chain: a public dial-up in West Germany and the X.25 links of the universities of Bremen and Karlsruhe, Tymnet, a dial-out modem pool at a McLean, Virginia, defense contractor, and LBL, from which he went on to ARPANET, MILNET and LAN machines closely linked to the hosts he had entered [1] (**Confirmed**) [`T1090.003`; `T1021`, `T1018`, `T1041`, Inferred]. At Bremen he had system-manager privileges, disabled accounting and used the university's X.25 links [1] (**Confirmed**).

1.9 What he did and what he got

Before LBL detected him he entered a computer used for real-time control of a medical experiment, and the paper says a patient might have been severely injured had he not been caught; elsewhere he destroyed several tasks and unknowingly caused the loss of physics experiment data [1] (**Confirmed**). The paper says he uncovered little information that was not already public, but he reached unclassified abstracts of US Army nuclear, biological and chemical warfare plans for central Europe [1] (**Confirmed**). His civil liability under California law for computing, network and tracing costs exceeded $100,000 [1] (**Confirmed**).

The paper also mentions a separate set of about 130 break-ins on NASA's SPAN network, also from West Germany, and, pending prosecution, declines to conjecture about how they relate to the LBL intrusions [1] (**Confirmed**). This study does not cover them.

Part 2: the timeline

Date	Event	Grade	Sources
26 Feb 1980 (rev. 15 Apr 1980)	James Anderson's report on computer security threat monitoring argues audit trails can detect penetration and names the masquerader, legitimate user and clandestine user	Confirmed	[28]
1986	Dorothy Denning's intrusion-detection model: violations show up as abnormal usage in audit records	Confirmed	[29]
May to Nov 1986	At least five diskettes handed over in East Berlin, at least 15,000 DM each	Reported	[9]
Months before Aug 1986	Modem attacks through the McLean contractor's dial-out pool are already under way	Confirmed	[1]
Aug 1986	LBL's accounting program fails to balance: a new account with no billing address	Confirmed	[1]
Aug 1986	Book and later interviews: a 75-cent discrepancy, about nine seconds of unbilled time, on Stoll's second day	Reported	[7] [20]
1986, soon after	The National Computer Security Center reports an attempt from LBL on one of its computers over MILNET	Confirmed	[1]
1986	Trace reaches a Tymnet dial-up in Oakland, then, with a court order and the telephone company, the McLean modem pool	Confirmed	[1]
8 Dec 1986	US request for help reaches the Deutsche Bundespost	Reported	[9]
Dec 1986	Bremen University, puzzled by transatlantic data bills, files a complaint against persons unknown	Reported	[9]
About Jan 1987	Bundespost specialists locate Bremen University, then Markus Hess	Reported	[9]
Jan 1987	LBL security managers set up the SDI sting (NYT, 1988)	Reported	[5]
1987	The intruder reads the bait files for more than an hour; the trace completes	Confirmed	[1]
1987, a few months later	A letter from someone in the United States asks for the bait material; LBL passes it to the FBI	Confirmed	[1]
23 Jun 1987	Hess's flat searched (German encyclopedia, uncited) and Hess questioned in Germany, per NYT in June 1987	Reported	[5] [27]
17 Apr 1988	NYT (John Markoff): the intruder has been questioned but not charged; LBL declines to name the McLean company	Reported	[5]
24 Apr 1988	Pittsburgh Post-Gazette names the letter writer as Laszlo J. Balogh	Reported	[5]
May 1988	"Stalking the Wily Hacker" published in *Communications of the ACM*	Confirmed	[1] [2] [3]
Mid or summer 1988	Hans Huebner ("Pengo") tells West German authorities	Confirmed (his own statement)	[11] [12]
5 Jul 1988	Karl Koch turns himself in to the Verfassungsschutz	Reported	[19]

Date	Event	Grade	Sources
Oct 1988	Koch gives a statement to the BKA	Reported	[14]
2 to 3 Nov 1988	Internet worm released on the evening of 2 November; Stoll posts one of the first public warnings on RISKS	Confirmed	[36] [37] [40]
8 Nov 1988	NCSC hosts a worm post-mortem in Baltimore	Confirmed	[37]
Dec 1988	CERT/CC established by DARPA at the SEI, Carnegie Mellon	Confirmed	[34]
10 Jan 1989	Stoll asks RISKS readers to help title his Doubleday book	Confirmed	[6]
2 Mar 1989	Three arrests after house searches; the Interior Ministry confirms the suspects supplied the KGB	Reported	[8] [12] [16]
3 Mar 1989	The Federal Court of Justice refuses an arrest warrant for "Markus H."	Reported	[10]
5 Mar 1989	DER SPIEGEL cover report on the hackers	Reported	[9]
6 Mar 1989	*taz* quotes a Federal Prosecutor's spokesman: certainly not a top espionage case	Reported	[10]
10 Mar 1989	Huebner's own statement on RISKS	Confirmed (his own statement)	[11]
23 May and 1 Jun 1989	Koch goes missing, then is found burned to death in a forest near Celle	Reported	[21] [13]
Aug 1989	Three hackers indicted on espionage charges (AP report of 17 August)	Reported	[15]
30 Sep 1989	Stoll posts the book's details: Doubleday, 1989	Confirmed	[7] [4]
Oct 1989	The WANK worm exposes coordination problems among response teams	Confirmed	[44]
15 Feb 1990	Verdict at the court in Celle: suspended sentences for Carl, Hess and Brzezinski	Reported	[17] [18]
1990	FIRST formed	Confirmed	[44]
15 Jan to 3 May 1991	Bill Cheswick's "Berferd" jail at AT&T, citing Stoll as having done the job before	Confirmed	[30]
7 Mar 1991	United States v. Morris affirmed by the Second Circuit	Confirmed	[41]
Jul 1991	RFC 1244 frames "Protect and Proceed" against "Pursue and Prosecute" and cites both Stoll works	Confirmed	[34]
1994	Cheswick and Bellovin, *Firewalls and Internet Security: Repelling the Wily Hacker*	Confirmed	[31]
Sep 1997	RFC 2196 obsoletes RFC 1244 and keeps both Stoll references	Confirmed	[35]
1999	The Honeynet Project is founded	Confirmed	[33]
Aug 2007	RFC 4949 defines "honey pot"	Confirmed	[32]
2016 and 2019	Stoll interviews in California Magazine and WIRED add later details	Reported	[20] [22]

Date	Event	Grade	Sources
2026	Hess's own site lists Stoll's DEF CON 34 talk, "Stalking the Wily Hacker: 40 years later"	Reported	[23]

Part 3: the investigation

3.1 Detection

The first clue was the accounting error [1] (**Confirmed**). Soon afterwards the National Computer Security Center (NCSC) reported that someone at LBL had tried to break into one of its computers over MILNET [1] (**Confirmed**). Among intelligence and security bodies the paper names the NCSC (its references give the NCSC's address as Ft. Meade, Md.) and, in its acknowledgements, the Air Force Office of Special Investigations; it never names the NSA or the CIA [1] (**Confirmed**, a text search of the paper). DER SPIEGEL describes the NCSC as a division of the NSA at Fort Meade [9] (**Reported**).

3.2 Watching without being seen

LBL attached printers and recorders to all incoming ports. Once it found he came in through the X.25 ports, it recorded both directions of traffic on those lines and so captured virtually every session [1] (**Confirmed**). The monitoring was off-line, on printers and PCs fed from RS-232 lines, invisible to an intruder who held system privileges, and it avoided modifying the operating system [1] (**Confirmed**). Alarms on the incoming lines watched for the account names he had stolen and paged the operator by modem; line noise could be injected when he touched sensitive systems [1] (**Confirmed**).

Denning's 1986 model notes that Berkeley 4.2 UNIX audited command usage but not file access [29] (**Confirmed**). That this gap is why Stoll relied on printers on incoming lines is a retelling in the English Wikipedia article on the book [24] (**Reported**).

3.3 Working around a reader of email

LBL kept a detailed logbook, like a lab notebook. Staff discussed the case by telephone because the intruder read their email, and they planted false emails to reassure him [1] (**Confirmed**).

3.4 The trace

The trace first reached a dial-up Tymnet port in Oakland. With a court order and the telephone company's help it reached a dial-out modem pool at a defense contractor in McLean, Virginia [1] (**Confirmed**). The paper does not name the contractor, and in 1988 LBL officials declined to name it to the New York Times [5] (**Reported**). Stoll named it as the MITRE Corporation in a 2016 interview [20] (**Reported**); the book is said to name it too, but the book was not opened. After the contractor closed its modems, Tymnet obtained full X.25 calling addresses that pointed to the universities of Bremen and Karlsruhe and to a public dial-up modem in another German city [1] (**Confirmed**). Tracing was coordinated among LBL, Tymnet, Bremen University and the Deutsche Bundespost [1] (**Confirmed**).

Other clues pointed abroad: packet round-trip timing, AT&T rather than Berkeley UNIX habits, German passwords, and an activity peak around noon Pacific time [1] (**Confirmed**).

DER SPIEGEL reports that the Americans asked the Bundespost for help on 8 December 1986, that Post specialists found Bremen University and then Hess about a month later, and that the trap-and-trace had no

judge's order, so the Bremen prosecutor could not take the case on [9] (**Reported**). The German Wikipedia article on the case dates a search of Hess's flat to 23 June 1987, without a citation, and says the investigation was later dropped because the trace was unauthorised [27] (**Reported**). The NYT of April 1988 also places the West German's detention and questioning in about June 1987 [5] (**Reported**).

3.5 The bait

LBL created fictitious SDI memos on an obscure LBL computer, with a mailing list and form letters offering documents by post from a secretary who did not exist; any read set off an alarm. He read them for more than an hour, long enough for the telephone technicians to finish the trace [1] (**Confirmed**). The New York Times report of April 1988 dates the sting to January 1987 [5] (**Reported**). The name "Operation Showerhead" comes only from Stoll's 2016 interview [20]; the bait network's name "SDInet" appears in the book as Wikipedia retells it [24] and in the same interview [20] (**Reported**). The paper says alarmed files offer a way to both detect and classify intruders [1] (**Confirmed**).

A few months later a letter from someone in the United States asked to join the fictitious SDI list and requested classified information. LBL treated it as attempted espionage and left that part to the FBI [1] (**Confirmed**). The Pittsburgh Post-Gazette of 24 April 1988 named the writer as Laszlo J. Balogh, 43, of South Park near Pittsburgh, who had billed himself variously as a Hungarian refugee, a diamond dealer and an FBI informant, among other things; Stoll and LBL's Leroy Kerth said the name may have been a pseudonym [5] (**Reported**). DER SPIEGEL describes him as an arms dealer whom US authorities suspected of being a KGB agent [9]; its June 1989 article names the FBI [14] (**Reported**). In 2016 Stoll described the writer as a Bulgarian spy [20] (**Reported**); no 1988 to 1989 source opened here calls him Bulgarian, so this study does not adopt that detail (**Inferred**).

3.6 The agencies

Stoll was talking routinely with the FBI during live traces. Police agencies were relatively uninterested until a monetary loss could be put on the case, no single agency had clear responsibility, and the FBI grew more interested as new computer-crime laws took effect [1] (**Confirmed**). The book's account, as summarized by Wikipedia, has Stoll contacting the FBI, CIA, NSA and Air Force Office of Special Investigations, with confused jurisdiction and an FBI at first uninterested because no large loss or classified host was involved [24] (**Reported**). The paper's acknowledgements confirm help from the Air Force OSI and the NCSC [1] (**Confirmed**); the CIA and NSA contacts rest on the book [24] (**Reported**). As of May 1988 the FBI and the German BKA were still investigating; some subjects had been apprehended, and the author did not know the status of any prosecution [1] (**Confirmed**). The paper's acknowledgements single out the Bundespost and Tymnet for technical support, and credit the Bremen Public Prosecutor's office, the U.S. Department of Justice and the Alameda County District Attorney with the prosecution and legal work [1] (**Confirmed**).

Part 4: the German record and attribution

Everything in Part 4 is from the press, participants' statements and encyclopedias. No judgment text, indictment or official German statement was opened, so no claim here is Confirmed except where a participant wrote it himself (**Inferred**, this study's reading of its sources).

4.1 A group, not a lone intruder

The book follows one intruder for a year. DER SPIEGEL reported a group of four, with Hess and Huebner on the LBL machine at the same time, and Phrack World News named a core group of five [9] [12] (**Reported**). The lone-intruder frame is the tracker's view from LBL (**Inferred**). Hans Huebner ("Pengo") wrote on RISKS in March 1989 that he had been in a circle that tried to deal with an eastern intelligence service and that he told the German authorities in summer 1988 [11] (**Confirmed** as his statement). Huebner and Koch confessed under the espionage amnesty, which protected them from prosecution [26] (**Reported**).

4.2 The KGB sale

Reuters reported at the verdict that Peter Carl made numerous trips to East Berlin and handed floppy disks to a KGB agent code-named Sergei at the Soviet trade mission, and that the KGB paid about $54,000 [18] (**Reported**). DER SPIEGEL reported at least five diskettes handed over from May to November 1986 at a minimum of 15,000 DM each [9] (**Reported**). The diskette deliveries began before LBL detected the intruder in August 1986 (**Inferred** from [9] and [1]).

4.3 Koch's surrender and death

Karl Koch ("Hagbard") turned himself in to the Verfassungsschutz on 5 July 1988 [19] (**Reported**). DER SPIEGEL reported that he came forward on the advice of lawyer Johann Schwenn, who said Hamburg state office head Christian Lochte had promised the case would be dropped in return for useful information; instead the BKA and an investigating judge of the Federal Court of Justice questioned Koch as a suspect, and he gave a BKA statement in October 1988 [14] (**Reported**). Koch went missing on 23 May 1989 [21] and was found burned to death in a forest near Celle; DER SPIEGEL Geschichte dates the discovery to 1 June 1989 [21], while other accounts range from 30 May to 1 June [13] (**Reported**). Police thought it was suicide [13] (**Reported**).

4.4 Arrests

The Federal Prosecutor's Office in Karlsruhe confirmed three arrests on 2 March 1989 after house searches in Hannover and West Berlin, and the Interior Ministry confirmed that the suspects had supplied information to the KGB [12] (**Reported**). A contemporaneous expert article lists searches in Hamburg, Hannover, Karlsruhe and Berlin by the BKA [16], and RISKS reported arrests in Berlin, Hamburg and Hanover after an ARD Panorama broadcast [8] (**Reported**). The Federal Court of Justice refused an arrest warrant for "Markus H." on 3 March 1989 [10] (**Reported**). Interior Minister Friedrich Zimmermann hailed the break-up of a spy ring; Gerhard Boeden, president of the BfV, called it a new quality of hostile spying; and Federal Prosecutor General Kurt Rebmann criticised a premature damage assessment [9] (**Reported**). A Federal Prosecutor's spokesman told *taz* that it was certainly not a top espionage case, that nobody was charged with betraying secrets and that the material came only from peripheral systems [10] (**Reported**).

In April 1988 the intruder had been questioned but not charged; LBL officials said not enough evidence had been obtained under West German law [5] (**Reported**). About two years separate the trace in early 1987 from the March 1989 arrests [5] [8] (**Inferred**).

4.5 Indictment and trial

In August 1989 three hackers were indicted on espionage charges. Rebmann said it was his office's first prosecution of hackers for endangering national security, and the ring gave the KGB data from 12 countries [15] (**Reported**). On 15 February 1990 the court in Celle convicted Peter Carl (35), Markus Hess (28) and Dirk Brzezinski (30) of selling the KGB information from Western military databases, in what Reuters called West Germany's first computer-hacker trial; Judge Leopold Spiller said no serious damage to West Germany arose, the stated reason for suspended terms of up to two years [18] (**Reported**). Klaus Brunnstein's report of the oral verdict gives the sentences: Hess 20 months on probation and 10,000 DM, Brzezinski 14 months and 5,000 DM, Carl two years and 3,000 DM [17] (**Reported**). The same report says the court found 30 intrusions out of 450 attempts, did not apply the new computer-espionage paragraph, heard a defence argument that Stoll's printouts did not prove the Hannover man typed the Berkeley commands, and that the German edition of the book was barred from sale [17] (**Reported**). Trial expert Helmut Kurth's report played an important role [19] (**Reported**). Stoll testified as an expert witness [22] [25] (**Reported**).

Reuters calls it the district court in Celle [18]; no German court record was opened, so this study does not name the chamber (**Inferred**).

4.6 Attribution, graded

The KGB link rests on defendant and witness statements and on the Celle verdict as reported in the press [17] [18] [9] (**Reported**). It is consistent with Huebner's own account [11] (**Confirmed** as his statement). The May 1988 paper, written before the arrests, declines to say whether the intrusions were espionage, while calling the SDI letter attempted espionage [1] (**Confirmed**). Hess today runs a site that describes him as a former hacker and spy and links the ACM paper as the basis of the book [23] (**Reported**, self-published).

Part 5: the book and the record

The book is the reason the case is famous, and later retellings have drifted from the 1988 record. The table sets each popular detail against what the primary says.

Popular detail	What the opened record says	Grade
A 75-cent accounting error	The paper names no amount: a new account had no billing address [1]. The 75 cents comes from the book (as described in a review Stoll reposted [7]) and a 2016 interview, which adds nine seconds of unbilled time [20]. DER SPIEGEL says only a few dollars [9]	Paper Confirmed; 75 cents Reported
The contractor was MITRE	The paper and the 1988 press do not name it [1] [5]; Stoll did in 2016 [20]	Reported
One lone hacker	The paper describes one intruder [1]; the German press describes a group of four or five [9] [12]	Reported
Press figures of hundreds of machines entered	The paper: about 450 attempted, about 220 reachable, more than 30 entered [1]. Stoll corrected press figures in DER SPIEGEL to about 30 of at most 220 [9]	Confirmed (paper)
A Bulgarian spy wrote in	1988 to 1989 press: Laszlo J. Balogh, a self-described Hungarian refugee [5]; Stoll in 2016: a Bulgarian [20]	Reported

Popular detail	What the opened record says	Grade
The sentences were light because the Berlin Wall fell	Stoll said so in 2016 [20]; Reuters in 1990 gives the judge's stated reason, no serious damage [18]	Reported; the 1990 account is preferred
Stoll met Hess in the courthouse bathroom	Stoll's 2019 WIRED account; not in the book, and WIRED could not confirm it with Hess [22]	Reported
The first honeypot, the first intrusion detection, the first cyber espionage case	The paper documents alarmed bait files and off-line keystroke printers [1]; the "first" labels are later characterisations (Part 6)	Inferred

Stoll had announced the book on RISKS in January 1989 as a September Doubleday title about catching a spy on the Milnet, pointing readers to his paper and to RISKS 6.68 [6] (**Confirmed**), and posted its details in September 1989 [7] (**Confirmed**).

Part 6: legacy

6.1 Intrusion detection: practice between theory and tools

Anderson's 1980 report argued that security audit trails can detect penetration and described the masquerader, the legitimate user and the clandestine user [28] (**Confirmed**). Denning's model, from the IDES work funded by SPAWAR and the NSF, rests on the hypothesis that violations show up as abnormal patterns of system use in audit records [29] (**Confirmed**). Her masquerader example, browsing directories and running status commands, matches the behaviour Stoll describes [1] [29] (**Inferred**). The LBL case is best read as a well-known early practice case of audit-driven detection, between Anderson's theory and the first prototype systems, rather than the origin of intrusion detection (**Inferred**). Heberlein told WIRED that the Network Security Monitor at Lawrence Livermore automated much of what Stoll did by hand [22] (**Reported**).

6.2 Deception: from bait files to honeynets

Year	Step	Grade	Sources
1986 to 1987	LBL's alarmed SDI bait files and fake secretary	Confirmed	[1]
1991	Cheswick's "Berferd" at AT&T: a chroot jail with fake files, bogus password files and logged connections; it cites Stoll as having done the job before, and one lesson is to prepare monitoring kits in advance	Confirmed	[30]
1994	Cheswick and Bellovin's book is subtitled *Repelling the Wily Hacker*, which echoes Stoll's title	Confirmed (subtitle); the echo is Inferred	[31]
1999	The Honeynet Project is founded to learn attacker tools, tactics and motives and share the lessons	Confirmed	[33]
2007	RFC 4949 defines "honey pot" as a resource designed to attract crackers and intruders, cross-referenced to entrapment	Confirmed	[32]

This is a lineage, not a chain of causes: of the steps in this table, only the Berferd chapter was seen to cite Stoll [30]; links between the other steps are **Inferred**.

6.3 Incident response: the policy question

RFC 1244 (July 1991) frames the choice LBL faced as a policy decision. It sets "Protect and Proceed" against "Pursue and Prosecute", which lets an intruder continue until identified and which law enforcement favours, and asks who decides when law enforcement asks a site to stay open [34] (**Confirmed**). It lists monitoring and setting traps among containment decisions and says it can be worth risking some damage to identify an intruder [34] (**Confirmed**). Its bibliography lists both Stoll's paper and *The Cuckoo's Egg*, with Jon Postel's review calling the book essential reading [34] (**Confirmed**). RFC 2196 (September 1997), which obsoletes RFC 1244, keeps both references and the section [35] (**Confirmed**). That LBL is the model for the section is **Inferred**.

6.4 The 1988 worm and CERT/CC

The paper called for a central clearinghouse for security reports [1] (**Confirmed**). Six months after the paper appeared, Stoll, then at Harvard, posted one of the first public warnings about the Internet worm on RISKS, at about 3:45 AM, reporting the sendmail debug attack spreading on MILNET to more than 10 sites in 4 hours and ending "This is bad news." [36] [37] (**Confirmed**). MIT's chronology records his suggestion that MILNET sites might disconnect, notes that he believed the worm started from the MIT AI Lab, and lists him among the people involved [37] (**Confirmed**). Gene Spafford created the phage@purdue.edu list that evening as the ad hoc coordination channel [37] (**Confirmed**). The NCSC hosted a post-mortem in Baltimore on 8 November 1988 with NIST, DCA, DARPA, BRL, LLNL, CIA, UCB, MIT, Harvard, SRI, FBI and NCSC; no vendor attended [37] (**Confirmed**).

MIT's conclusion is that the "old boy network" worked but cannot be formalized, that authenticating callers and patches late at night was an open problem, and that sites which disconnected hurt themselves and the community [38] (**Confirmed**). RFC 1135 (December 1989) describes Berkeley and MIT teams exchanging code and alerting sites through that network, email and phone, and its bibliography lists Stoll's CACM paper, his *Computers and Security* piece of 1 December 1988 and the book [40] (**Confirmed**). RFC 1135 dates the release to the evening of 2 November 1988 and the scope to VAX and Sun-3 systems on 4.2 and 4.3 BSD [40] (**Confirmed**). MIT puts the Internet at about 60,000 computers in November 1988 [39] (**Confirmed**). Spafford's analysis is Purdue technical report 88-823; the Purdue record dates it 18 November 1988 while RFC 1135 cites 28 November [42] [40] (**Confirmed**, discrepancy noted; the report PDF was not read). His follow-up "Crisis and aftermath" appeared in CACM in June 1989 [43] (**Confirmed**, landing page only).

The Second Circuit affirmed Robert Morris's conviction under 18 U.S.C. 1030(a)(5)(A) on 7 March 1991: three years' probation, 400 hours of community service and a $10,050 fine plus supervision costs, with cleanup estimates from $200 to over $53,000 per installation [41] (**Confirmed**, read through the OpenJurist mirror).

FIRST's history says the worm response was isolated and uncoordinated with duplicated effort, that CERT/CC formed weeks later, and that DOE soon formed CIAC [44] (**Confirmed**). RFC 1244 dates CERT/CC to December 1988, established by DARPA and run by the SEI at Carnegie Mellon as a clearing house coordinating fixes with vendors [34] (**Confirmed**). It describes CIAC as a four-person Lawrence Livermore team for DOE incident response [34] (**Confirmed**). The SEI names Richard Pethia as CERT's founding director, from 1988 to 2016 [45] (**Confirmed**), and RFC 1281 (November 1991), by Pethia and Fraser of the SEI with Crocker, sets guidelines for secure operation of the Internet [46] (**Confirmed**). FIRST says the October 1989 WANK worm exposed coordination problems among response teams and that FIRST formed in 1990 in response [44] (**Confirmed**).

The chain reads: one site with no coordinating body in 1986 and 1987, ad hoc lists and phone trees in November 1988, CERT/CC and CIAC in late 1988 and 1989, FIRST in 1990. No primary opened says LBL caused CERT/CC; the worm is the documented trigger [44] (**Inferred** for the chain).

Part 7: the defender view

7.1 Ship the evidence off the host

The off-line printers stayed invisible to an intruder holding system privileges, while monitors on the host would have tipped him off [1] (**Confirmed**). He disabled accounting and audit trails where he could [1] (**Confirmed**). The modern form is to forward logs and session records to a system the attacker cannot reach (**Inferred**). D3FEND Remote Terminal Session Detection and Local Account Monitoring are the closest library countermeasures (Part 9.4).

7.2 Default and guessable credentials are the front door

Common account names and default passwords opened about 5 percent of the machines he tried [1]; 20 percent of LBL's own passwords fell to a dictionary [1] (**Confirmed**). CISA asked manufacturers on 15 December 2023 to eliminate default passwords [49] (**Confirmed**), and NIST SP 800-63B requires a blocklist check for common, expected or compromised passwords [50] (**Confirmed**; this edition's publication date and its position on forced expiry were not checked). LBL itself added password expiration after the case [1] (**Confirmed**); whether forced expiry is still good practice was not checked for this study.

7.3 Privileged helpers and the patch that does not end access

A single set-user-ID-root helper made him system manager, and programs he hid in system libraries outlived the patch of the original hole [1] (**Confirmed**). Inventory privileged binaries and compare system utilities against fresh, known-good copies, as LBL did [1] (**Confirmed** for LBL's practice). Patching alone is not enough once an intruder has had privileged access (**Inferred**).

7.4 Dormant accounts are persistence

He parked a privileged account for six months and preferred stealing unused accounts to creating new ones [1] (**Confirmed**). LBL deleted expired and shared accounts afterwards [1] (**Confirmed**). Reviewing dormant accounts is the modern counterpart (D3FEND Local Account Monitoring) (**Inferred**).

7.5 Decoys detect and hold

The alarmed SDI files detected the intruder and held him long enough to finish a trace [1] (**Confirmed**). D3FEND Decoy File is the modern countermeasure [47] (**Confirmed** that the page exists and describes decoy files). The library also carries MITRE Engage activities that fit the bait: EAC0005 Lures, EAC0011 Pocket Litter, EAC0003 System Activity Monitoring, EAC0002 Network Monitoring and EAC0020 Isolation [51] (**Inferred** mapping; ids **Confirmed** in the library's data).

7.6 Report, and know whom to call

Only five sites of the hundreds he tried, 1 to 2 percent, contacted LBL after seeing a login attempt [1] (**Confirmed**). Drifting clocks and unfamiliar log formats slowed the trace, and preparation, including knowing whom to call in law enforcement, made all the difference [1] (**Confirmed**). Keep clocks synchronised, keep log formats documented, and agree a "protect and proceed" or "pursue and prosecute" policy before an incident [34] (**Inferred** from the sources cited).

7.7 Library corrections

1. `NOTABLE_INCIDENTS.md`**, 1986 row: "First documented cyber espionage case".** Stoll's paper declines to say whether the intrusions were espionage [1], a Federal Prosecutor's spokesman called it certainly not a top espionage case [10], and no opened primary supports "first" [52]. Suggested wording: "Early, widely documented intrusion later tied to a KGB sale (Reported)".
2. `NOTABLE_INCIDENTS.md`**, 1986 row: Stoll's "honeypot technique pioneered active defense".** The paper documents alarmed bait files [1]; "honeypot" is a retrospective label [32], and "active defense" is not in the opened record. Suggested wording: "used alarmed bait files to hold the intruder for a trace".
3. `NOTABLE_INCIDENTS.md`**, 1988 Morris worm row: "~6,000 Unix machines crashed (~10% of the internet at the time)".** No primary opened for this study gives the 6,000 figure; MIT puts the whole Internet at about 60,000 computers [39]. Mark the figure as an estimate or "not checked".
4. `HONEYPOT_DECEPTION_REFERENCE.md`**: Engage ids.** It gives Lures as EAC0004 and Pocket Litter as EAC0009 [52]; the library's own `data/engage/engage_activities.jsonl` lists Lures as EAC0005 and Pocket Litter as EAC0011 [51] (**Confirmed**).

Part 8: what the record does not settle

- **Who typed which command.** The defence at Celle argued that the printouts did not prove the Hannover man ran the Berkeley commands [17] (**Reported**), and the German press describes a group on the LBL machine [9] (**Reported**). The paper attributes all activity to one intruder [1] (**Confirmed** that it does).
- **What the KGB received.** The press reports diskettes and payments [9] [18] but not their contents; the court said no serious damage arose [18] (**Reported**).
- **The German legal record.** No judgment text, indictment or official statement was opened. A future update should open them if they become reachable (**Inferred**).
- **The SPAN break-ins.** The paper mentions about 130 NASA SPAN intrusions, also from West Germany, and, pending prosecution, declines to conjecture about how they relate to the LBL intrusions [1] (**Confirmed**). They are out of scope here.

Part 9: MITRE mappings

This Part binds the verified record to MITRE ATT&CK v20.0, CAPEC, CWE and D3FEND. The intrusion predates ATT&CK by three decades, so every technique row is a retrospective mapping of behaviour that Stoll's paper describes [1], not a mapping MITRE publishes. Every technique id was checked against the library's `data/attack/technique_profiles.jsonl` and `superseded_by.jsonl` [51], and 23 of them against the live ATT&CK site (T1078, T1018, T1548.001 and T1556 were checked against the library data only), which serves v20.0 (for example, the T1110.001 page title reads "Brute Force: Password Guessing") [48]. Identifiers that could not be checked are left out. ATT&CK for ICS does not apply.

9.1 Objects

Object	ATT&CK id	Library page	Relationship
Group	none	none	ATT&CK has no group object for the Hannover hackers or the LBL intruder [51]
Software	none	none	No software object covers the tooling (shell scripts, Trojan login programs, a dictionary cracker) [51]
Campaign	none	none	No campaign object covers the 1986 to 1987 intrusions [51]
False friends, not linked	`C0012` Operation CuckooBees; `S1153` Cuckoo Stealer	not linked	Keyword matches only; both are unrelated modern activity and must not be linked to this case [51]

9.2 ATT&CK Enterprise techniques the record supports directly (16)

Tactics are the v20.0 tactics in the library's data [51]. The mapping grade is Confirmed when the paper describes the behaviour the technique names.

ID	Name	Tactic(s)	Dated event or report	Sources
T1068	Exploitation for Privilege Escalation	Privilege Escalation	GNU Emacs `movemail` set-user-ID-root flaw at LBL, 1986; `/usr/spool/at` and `vi` attempts	[1]
T1036.005	Masquerading: Match Legitimate Resource Name or Location	Stealth	Script renamed and placed as a periodically run utility, 1986; programs hidden in system libraries, reused a year later	[1]
T1110.001	Brute Force: Password Guessing	Credential Access	Common names and passwords against about 450 MILNET hosts and the modems dialled from McLean, 1986 to 1987	[1] [48]
T1110.002	Brute Force: Password Cracking	Credential Access	Offline dictionary cracking of downloaded password files, 1986 to 1987	[1]
T1003.008	OS Credential Dumping: /etc/passwd and /etc/shadow	Credential Access	Encrypted UNIX password files downloaded, 1986 to 1987	[1]
T1552.001	Unsecured Credentials: Credentials In Files	Credential Access	Plain-text passwords in files and saved mail, leading to a Cray, 1986 to 1987	[1]

ID	Name	Tactic(s)	Dated event or report	Sources
T1078	Valid Accounts	Stealth, Persistence, Privilege Escalation, Initial Access	Logins with cracked passwords within a week, 1986 to 1987	[1]
T1078.001	Valid Accounts: Default Accounts	Stealth, Persistence, Privilege Escalation, Initial Access	root, guest, system, field accepted on about 5 percent of targets	[1]
T1078.003	Valid Accounts: Local Accounts	Stealth, Persistence, Privilege Escalation, Initial Access	Stolen existing unused accounts, preferred to creating new ones	[1]
T1136.001	Create Account: Local Account	Persistence	Privileged account on a gateway, left unused six months	[1]
T1033	System Owner/User Discovery	Discovery	Checked who was logged in and left if a system manager was on	[1]
T1083	File and Directory Discovery	Discovery	Keyword searches for nuclear, sdi, kh-11, norad	[1]
T1213	Data from Information Repositories	Collection	Browsed databases; reached unclassified Army NBC plan abstracts	[1]
T1114.001	Email Collection: Local Email Collection	Collection	Read mail, partly for signs of discovery; LBL moved case talk to the phone	[1]
T1685	Disable or Modify Tools	Defense Impairment	Disabled accounting and audit trails, including at Bremen	[1] [51]
T1090.003	Proxy: Multi-hop Proxy	Command and Control	Chained German dial-up, Bremen X.25, Tymnet, McLean modems and LBL as a hub	[1]

Notes. `T1685` is the v20.0 home of the revoked `T1562` Impair Defenses and `T1562.001`, per `data/attack/superseded_by.jsonl` [51]; the sub-technique `T1685.004` (Linux audit system) is not used, because this was UNIX process accounting, not Linux auditd. The paper describes the chained, redundant path through Bremen, Tymnet, the McLean modems and LBL in detail [1], so the mapping is treated as direct.

9.3 Inferred mappings (9)

These rows are the study's reasoning from the paper and are labelled **Inferred**. The paper describes the effect but not the mechanism the technique names.

ID	Name	Tactic(s)	What the paper says	Sources
T1005	Data from Local System	Collection	Searched local files after entry	[1]
T1056	Input Capture	Collection, Credential Access	Trojan horses captured passwords passively; the method is not described (T1556 Modify Authentication Process is the alternative reading)	[1]
T1133	External Remote Services	Persistence, Initial Access	Entry through X.25 and Tymnet ports and dial-up modems	[1]
T1021	Remote Services	Lateral Movement	Leapfrogged from LBL to military bases and linked LAN machines; protocols not named	[1]

ID	Name	Tactic(s)	What the paper says	Sources
T1018	Remote System Discovery	Discovery	Tried closely linked LAN machines	[1]
T1087.001	Account Discovery: Local Account	Discovery	`who`/`finger` queries of logged-in users; Local Account is the nearest sub-technique	[1]
T1548.001	Abuse Elevation Control Mechanism: Setuid and Setgid	Privilege Escalation	`movemail` ran set-user-ID root	[1]
T1053	Scheduled Task/Job	Execution, Persistence, Privilege Escalation	The planted script ran as a periodic utility; the scheduler is not named, so no sub-technique is mapped	[1]
T1041	Exfiltration Over C2 Channel	Exfiltration	Moved files over his interactive session	[1]

Data Staged (`T1074`) and the At and Cron sub-techniques (`T1053.002`, `T1053.003`) are left out because the paper does not support them (**Inferred**).

9.4 CAPEC, CWE and D3FEND

No CVE exists for this case. The CAPEC entries below are a selection of those ATT&CK links to the mapped techniques, chosen where the pattern fits the record in the library's data; each has a library page [51] (**Confirmed** for the links).

CAPEC	Name	Via technique
CAPEC-70	Try Common or Default Usernames and Passwords	`T1078.001`
CAPEC-560	Use of Known Domain Credentials	`T1078`
CAPEC-49	Password Brute Forcing	`T1110.001`
CAPEC-55	Rainbow Table Password Cracking	`T1110.002`
CAPEC-112	Brute Force	`T1110` (parent)
CAPEC-191	Read Sensitive Constants Within an Executable	`T1552.001`
CAPEC-639	Probe System Files	`T1552.001`
CAPEC-577	Owner Footprinting	`T1033`
CAPEC-575	Account Footprinting	`T1087` (parent)
CAPEC-127	Directory Indexing	`T1083`

The CAPEC names are the library pages' titles. The fit is ATT&CK's, not this study's: CAPEC-55 describes rainbow tables, while the intruder used a dictionary [1].

CWE. The weaknesses the record describes match these entries in the library's `data/weaknesses/cwe.jsonl` [51]: CWE-1392 Use of Default Credentials and CWE-1393 Use of Default Password (the default accounts), CWE-521 Weak Password Requirements (the dictionary passwords), and CWE-269 Improper Privilege Management and CWE-250 Execution with Unnecessary Privileges (the set-user-ID-root `movemail`). With no

CVE and no vendor record, every CWE assignment here is **Inferred**. See the CWE Reference and the CAPEC Reference.

D3FEND. The library's `data/attack/technique_to_d3fend.jsonl` maps these countermeasures to the techniques above, and each has a library page [51] (**Confirmed** for the rows).

D3FEND countermeasure	Techniques it counters	Where it meets the record
Change Default Password	`T1078.001`, `T1110.001`	root, guest, system, field (Part 1.2)
Strong Password Policy	`T1110.001`, `T1110.002`	20 percent of LBL passwords cracked (Part 1.5)
Password Rotation	`T1110.001`, `T1110.002`	LBL's password expiration after the case
Multi-factor Authentication	`T1110.001`, `T1110.002`, `T1003.008`	Cracked and guessed passwords were the only factor
Account Locking	`T1078.001`, `T1078.003`, `T1136.001`	Locking unused and default accounts he preferred to steal (Part 1.6)
Local Account Monitoring	`T1078.003`, `T1136.001`	The six-month dormant gateway account (Part 1.6)
Remote Terminal Session Detection	`T1021`, `T1090.003`, `T1018`	The line alarms on stolen account names (Part 3.2)
Connection Attempt Analysis	`T1021`	Failed logins that only 1 to 2 percent of sites reported (Part 7.6)
File Integrity Monitoring	`T1036.005`	Comparing utilities with fresh copies (Part 7.3)
Decoy File	`T1083`, `T1005`, `T1552.001`	The alarmed SDI memos (Part 3.5) [47]
Decoy User Credential	`T1110.001`, `T1110.002`, `T1003.008`	A modern counterpart to watching for stolen account names

Two further decoy countermeasures, Decoy Environment and Decoy Network Resource, describe the Berferd jail and the bait network more closely than any single file (**Inferred**). For `T1068` the library's D3FEND rows are memory-corruption hardening and do not fit a set-user-ID logic flaw; Software Update fits the patching LBL had already done for the `at` and `vi` holes, but the library does not map it to `T1068`, so that pairing is **Inferred** [51]. See the D3FEND Reference.

9.5 ATLAS

MITRE ATLAS does not apply: no AI or machine-learning system is involved (**Inferred**).

9.6 Navigator layer

- Enterprise: `navigator/library-layers/cuckoos-egg-1986.json` (open in Navigator), domain `enterprise-attack`, ATT&CK version 20, the 25 techniques of Parts 9.2 and 9.3, each shown under its tactics with a comment naming the behaviour and the source numbers of this study. It is listed in the Navigator layer index.

Scores mean only how the mapping is graded: 100 for a behaviour the paper describes directly (Part 9.2), 40 for an Inferred mapping (Part 9.3). The layer is a retrospective, curated mapping, not an official MITRE mapping.

Cross-cutting themes

- **The basics carried the attack.** Default names, dictionary passwords, passwords in files and a privileged helper with a logic flaw [1]. None needed a novel exploit, and CISA's 2023 alert on default passwords [49] and the current NIST SP 800-63B blocklist requirement [50] shows the same weaknesses are still being addressed (**Inferred**).
- **Watching was a choice with costs.** LBL let the intruder continue. The paper puts his civil liability for computing, network and tracing costs above $100,000 [1]; he destroyed several tasks and caused the loss of physics data, and before detection he had entered a medical-experiment control computer where, the paper says, a patient might have been injured [1]. RFC 1244 later made that trade an explicit policy decision [34]. The case shows both what "pursue and prosecute" can achieve and what it puts at risk (**Inferred**).
- **Visibility depends on where the sensor sits.** Monitoring the intruder could see would have ended the case; off-line printers kept it alive [1]. Audit trails on the host were exactly what he disabled [1].
- **Jurisdiction lagged the network.** No US agency had clear responsibility [1], the German trace had no judge's order [9], and two years passed before arrests [5] [8]. The trial applied existing law rather than the new computer-espionage paragraph [17] (**Reported**).
- **Overstated and understated.** Overstated: "first cyber espionage case", "first honeypot" and the claim that the book's details are documented fact; the paper stops short of calling the intrusions espionage [1] and the popular details drift from it (Part 5). Understated: how much of the success came from cooperation by Tymnet, the telephone companies, Bremen University and the Bundespost [1], and how few of the sites he attacked ever noticed or said anything [1] (**Inferred**, this study's reading of the sources cited).

Sources

#	Source	URL	Opened	Grade
1	Clifford Stoll, "Stalking the Wily Hacker", *Communications of the ACM* 31(5), pp. 484-497, May 1988 (full text, textfiles.com copy)	http://pdf.textfiles.com/academics/wilyhacker.pdf	3 Nov 2026	Confirmed
2	Crossref metadata for DOI 10.1145/42411.42412	https://api.crossref.org/works/10.1145/42411.42412	3 Nov 2026	Confirmed
3	CACM landing page, "Stalking the Wily Hacker" (abstract only)	https://cacm.acm.org/research/stalking-the-wily-hacker/	3 Nov 2026	Confirmed
4	US National Library of Medicine archive exhibit, *The Cuckoo's Egg*, 1989 (bibliographic)	https://www.nlm.nih.gov/archive/20120104/onceandfutureweb/database/secb/case5-artifacts/photo10.html	3 Nov 2026	Confirmed
5	RISKS Digest 6.68: NYT News Service (John Markoff, 17 Apr 1988) and Pittsburgh Post-Gazette (Roger Stuart, 24 Apr 1988) reposts	https://catless.ncl.ac.uk/Risks/6/68	3 Nov 2026	Reported
6	RISKS Digest 8.6: Cliff Stoll, "Name this book", 10 Jan 1989	https://catless.ncl.ac.uk/Risks/8/6	3 Nov 2026	Confirmed
7	RISKS Digest 9.30: Cliff Stoll posts the book's details and a Cosmopolitan review, 30 Sep 1989	https://catless.ncl.ac.uk/Risks/9/30	3 Nov 2026	Confirmed (post); Reported (review)
8	RISKS Digest 8.35: Klaus Brunnstein, arrests report, 2 Mar 1989	https://catless.ncl.ac.uk/Risks/8/35	3 Nov 2026	Reported
9	DER SPIEGEL 10/1989, "Er konnte an jedem Ort der Welt sitzen", 5 Mar 1989 (also served at https://www.spiegel.de/spiegel/print/d-13493011.html)	https://www.spiegel.de/politik/er-konnte-an-jedem-ort-der-welt-sitzen-a-b3143faa-0002-0001-0000-000013493011	3 Nov 2026	Reported
10	*taz*, Juergen Voges, 6 Mar 1989	http://www.taz.de/!1819924/	3 Nov 2026	Reported
11	RISKS Digest 8.37: Hans Huebner ("Pengo"), "Re: News from the KGB/Wily Hackers", 10 Mar 1989	https://catless.ncl.ac.uk/Risks/8/37	3 Nov 2026	Confirmed (his own statement)
12	Phrack 25, Phrack World News XXV/2, 29 Mar 1989	https://phrack.org/issues/25/phrack-world-news-xxvpart-2.html	3 Nov 2026	Reported
13	RISKS Digest 8.77: Klaus Brunnstein on Karl Koch's death, 5 Jun 1989	https://catless.ncl.ac.uk/Risks/8/77	3 Nov 2026	Reported
14	DER SPIEGEL, "Alle grossen Anarchisten starben am 23.", 11 Jun 1989	https://www.spiegel.de/spiegel/print/d-13493816.html	3 Nov 2026	Reported
15	RISKS Digest 9.13: AP (Frankfurt) via Boston Globe, 17 Aug 1989, indictment	https://catless.ncl.ac.uk/Risks/9/13	3 Nov 2026	Reported
16	Hartmut Pohl and Ludger Huette, "Computerspionage: Ist die Katastrophe unvermeidbar?", bonntendenz, 1989	https://www.softscheck.com/pdf/Computer_Spionage_Ist_die_Katastrophe_unvermeidbar__890000_.pdf	3 Nov 2026	Reported

#	Source	URL	Opened	Grade
17	RISKS Digest 9.69: Klaus Brunnstein, "3 KGB Wily Hackers convicted, mild sentences", 15 Feb 1990	https://catless.ncl.ac.uk/Risks/9/69	3 Nov 2026	Reported
18	Reuters via Los Angeles Times, "2 W. Germans Get Suspended Terms as Computer Spies", 16 Feb 1990	https://www.latimes.com/archives/la-xpm-1990-02-16-mn-667-story.html	3 Nov 2026	Reported
19	Klaus Schmeh, "Die KGB-Hacker", Telepolis, 2 Jan 2011 (interview with trial expert Helmut Kurth)	https://www.telepolis.de/features/Die-KGB-Hacker-3387740.html?seite=all	3 Nov 2026	Reported
20	Martin Snapp, "How a Berkeley Eccentric Beat the Russians", California Magazine, 28 Mar 2016 (Stoll interview)	https://alumni.berkeley.edu/california-magazine/spring-2016-war-stories/how-berkeley-eccentric-beat-russians-and-then-made	3 Nov 2026	Reported
21	Frank Patalong, "Karl Koch alias Hagbard Celine: Tod eines Hackers", DER SPIEGEL Geschichte, 23 May 2019	https://www.spiegel.de/geschichte/karl-koch-alias-hagbard-celine-tod-eines-hackers-a-1268203.html	3 Nov 2026	Reported
22	Andy Greenberg, "Meet the Mad Scientist Who Wrote the Book on How to Hunt Hackers", WIRED, 18 Dec 2019	https://www.wired.com/story/meet-the-mad-scientist-who-wrote-the-book-on-how-to-hunt-hackers/	3 Nov 2026	Reported
23	thewilyhacker.de (site run by Markus Hess, in German)	https://thewilyhacker.de	3 Nov 2026	Reported (self-published)
24	Wikipedia, "The Cuckoo's Egg (book)" (used for the book's version only)	https://en.wikipedia.org/wiki/The_Cuckoo%27s_Egg_%28book%29	3 Nov 2026	Reported
25	Wikipedia, "Markus Hess"	https://en.wikipedia.org/wiki/Markus_Hess	3 Nov 2026	Reported
26	Wikipedia, "Karl Koch (hacker)"	https://en.wikipedia.org/wiki/Karl_Koch_%28hacker%29	3 Nov 2026	Reported
27	Wikipedia (German), "KGB-Hack"	https://de.wikipedia.org/wiki/KGB-Hack	3 Nov 2026	Reported
28	James Anderson, "Computer Security Threat Monitoring and Surveillance", 26 Feb 1980, rev. 15 Apr 1980 (NIST CSRC copy)	https://csrc.nist.gov/csrc/media/publications/conference-paper/1998/10/08/proceedings-of-the-21st-nissc-1998/documents/early-cs-papers/ande80.pdf	3 Nov 2026	Confirmed
29	Dorothy Denning, "An Intrusion-Detection Model", 1986 IEEE Symposium on Security and Privacy version (CMU course copy)	https://users.ece.cmu.edu/~adrian/731-sp04/readings/denning-ids.pdf	3 Nov 2026	Confirmed
30	Cheswick and Bellovin, *Firewalls and Internet Security*, 1st ed., ch. 10, "An Evening with Berferd"	https://www.wilyhacker.com/1e/chap10.pdf	3 Nov 2026	Confirmed
31	wilyhacker.com, book landing page, *Repelling the Wily Hacker*	https://www.wilyhacker.com/	3 Nov 2026	Confirmed
32	RFC 4949, Internet Security Glossary, Version 2, Aug 2007	https://www.rfc-editor.org/rfc/rfc4949.txt	3 Nov 2026	Confirmed
33	The Honeynet Project, About	https://www.honeynet.org/about/	3 Nov 2026	Confirmed

#	Source	URL	Opened	Grade
34	RFC 1244, Site Security Handbook, Jul 1991	https://www.rfc-editor.org/rfc/rfc1244.txt	3 Nov 2026	Confirmed
35	RFC 2196, Site Security Handbook, Sep 1997	https://www.rfc-editor.org/rfc/rfc2196.txt	3 Nov 2026	Confirmed
36	RISKS Digest 7.69: Cliff Stoll's worm warning, 3 Nov 1988	https://catless.ncl.ac.uk/Risks/7/69	3 Nov 2026	Confirmed
37	Eichin and Rochlis, "With Microscope and Tweezers" (MIT, 1988), chronology	https://web.mit.edu/eichin/www/virus/chronology.html	3 Nov 2026	Confirmed
38	Same, conclusion	https://web.mit.edu/eichin/www/virus/conclusion.html	3 Nov 2026	Confirmed
39	Same, introduction	https://web.mit.edu/eichin/www/virus/intro.html	3 Nov 2026	Confirmed
40	RFC 1135, The Helminthiasis of the Internet, Dec 1989	https://www.rfc-editor.org/rfc/rfc1135.txt	3 Nov 2026	Confirmed
41	United States v. Morris, 928 F.2d 504 (2d Cir. 1991), OpenJurist mirror	https://openjurist.org/928/f2d/504/united-states-v-morris	3 Nov 2026	Confirmed
42	Eugene Spafford, "The Internet Worm Program: An Analysis", Purdue e-Pubs record (PDF not read)	https://docs.lib.purdue.edu/cstech/702/	3 Nov 2026	Confirmed (record)
43	Eugene Spafford, "Crisis and aftermath", CACM, Jun 1989 (landing page)	https://cacm.acm.org/research/crisis-and-aftermath/	3 Nov 2026	Confirmed
44	FIRST, "FIRST History"	https://www.first.org/about/history	3 Nov 2026	Confirmed
45	SEI, CERT Division page	https://www.sei.cmu.edu/about/divisions/cert/	3 Nov 2026	Confirmed
46	RFC 1281, Guidelines for the Secure Operation of the Internet, Nov 1991	https://www.rfc-editor.org/rfc/rfc1281.txt	3 Nov 2026	Confirmed
47	D3FEND, Decoy File (D3-DF)	https://d3fend.mitre.org/technique/d3f:DecoyFile/	3 Nov 2026	Confirmed
48	ATT&CK, T1110.001 Brute Force: Password Guessing (live site, v20.0)	https://attack.mitre.org/techniques/T1110/001/	3 Nov 2026	Confirmed
49	CISA, Secure by Design Alert: How Manufacturers Can Protect Customers by Eliminating Default Passwords, 15 Dec 2023	https://www.cisa.gov/resources-tools/resources/secure-design-alert-how-manufacturers-can-protect-customers-eliminating-default-passwords	3 Nov 2026	Confirmed
50	NIST SP 800-63B, 800-63-4 edition	https://pages.nist.gov/800-63-4/sp800-63b.html	3 Nov 2026	Confirmed

#	Source	URL	Opened	Grade
51	Library data: `data/attack/technique_profiles.jsonl`, `superseded_by.jsonl`, `technique_to_d3fend.jsonl`, the groups, software and campaigns files, `data/weaknesses/cwe.jsonl`, `data/engage/engage_activities.jsonl`, `scripts/validate_navigator.py`	https://github.com/TeamStarWolf/TeamStarWolf/tree/main/data/attack	3 Nov 2026	Confirmed
52	Library pages: `NOTABLE_INCIDENTS.md` (1986 and 1988 rows), `CYBERSECURITY_BOOK_LIST.md`, `HONEYPOT_DECEPTION_REFERENCE.md`	https://github.com/TeamStarWolf/TeamStarWolf/blob/main/NOTABLE_INCIDENTS.md	3 Nov 2026	Confirmed

© 2026 The MITRE Corporation. This work is reproduced and distributed with the permission of The MITRE Corporation. License: ATT&CK Terms of Use. ATT&CK® and MITRE ATT&CK® are registered trademarks of The MITRE Corporation. This project is not affiliated with or endorsed by MITRE.

© The MITRE Corporation. Includes material from the Common Weakness Enumeration (CWE™), used under the CWE Terms of Use. https://cwe.mitre.org/

© The MITRE Corporation. Includes material from the Common Attack Pattern Enumeration and Classification (CAPEC™), used under the CAPEC Terms of Use. https://capec.mitre.org/

© The MITRE Corporation. Includes material from MITRE D3FEND™, used under the D3FEND Terms of Use. https://d3fend.mitre.org/

© The MITRE Corporation. Includes material from MITRE Engage™, used under the MITRE Engage Terms of Use. `https://engage.mitre.org/`

The terms for every MITRE dataset used here are recorded in THIRD_PARTY_NOTICES.md.

Related references

- Notable Incidents (the 1986 and 1988 rows; corrections in Part 7.7)
- Threat Actors and Malware Families: no entry is needed for this case, which has no ATT&CK group or software object
- CVE Reference: no CVE exists for the `movemail` flaw
- Cybersecurity Book List (*The Cuckoo's Egg*)
- Honeypot and Deception Reference and Incident Response Reference
- Other case studies: Stuxnet, APT41: the public record and Log4Shell, for how later intrusions used the same credential and privilege techniques
- MITRE technique pages: T1068, T1036.005, T1110.001, T1110.002, T1003.008, T1552.001, T1078, T1078.001, T1078.003, T1136.001, T1033, T1083, T1213, T1114.001, T1685, T1090.003, and the Inferred rows in Part 9.3, including T1087.001
- CWE Reference, CAPEC Reference, D3FEND Reference
- Navigator layers
- All case studies